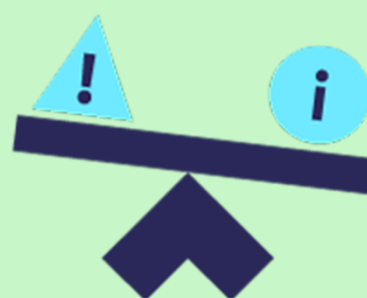




Oslo

Byrådsavdeling for finans

Veileder om risikostyring av informasjonssikkerhet



Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

1	Om veilederen	3
1.1	Veilederens målgruppe og oppbygging	4
1.2	Roller og ansvar	4
2	Risikostyring.....	5
2.1	Om risiko og risikostyring	5
2.2	Formålet med risikostyring.....	6
3	Risikostyring av informasjonssikkerhet i Oslo kommune	7
3.1	Byrådsavdelingens styring og oppfølging	7
3.2	Virksomhetsledelsens styring og oppfølging	8
3.3	Systemeiers styring og oppfølging.....	9
4	Rammer for risikostyring av informasjonssikkerhet	9
4.1	Kultur og kompetanse	9
4.2	Krav til informasjonssikkerhet og risikostyring	10
4.3	Policy for risikostyring	11
4.4	Delegering av myndighet og oppgaver	11
4.5	Risikokriterier	12
4.6	Risikoregister	15
5	Metodikk for risikostyring av informasjonssikkerhet.....	16
5.1	Planlegging	17
5.2	Risikovurdering.....	18
5.3	Risikohåndtering.....	19
5.4	Dokumentasjon	21
5.5	Oppfølging av risiko.....	22

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

1 Om veilederen



Dette er en veileder til arbeid med risikostyring av informasjonssikkerhet i Oslo kommune, og inngår i kommunens rammeverk av veiledere, verktøy og maler for informasjonssikkerhet. Innholdet i veilederen går nærmere inn på disse oppgavene fra hovedveilederne:

- Virksomhetens informasjonssikkerhetsoppgaver
 - Kapittel 3.1 – Risikobasert virksomhetsstyring
- Byrådsavdelingens informasjonssikkerhetsoppgaver
 - Kapittel 3.1 – Risikobasert virksomhetsstyring
- Systemeiers informasjonssikkerhetsoppgaver
 - Kapittel 3.2 - Risikostyring

Formålet med veilederen er å beskrive hva risikostyring er og hvordan det kan bidra til at virksomhetens verdier beskyttes på en forsvarlig og helhetlig måte. Veilederen gir en oversikt over hvilke aktiviteter som inngår i risikostyring av informasjonssikkerhet.

Oppgavene er utledet fra krav til informasjonssikkerhet i lovverk og kommunens interne styringsdokumenter, samt anbefalinger om risikostyring i ISO 27001/27005.

Hvert tema i denne veilederen begynner med en kort ingress som sier noe om målet for temaet, deretter følger en eller flere tilhørende oppgaver.



Oppgave. Byrådsavdelingens oppgaver har gul bakgrunn



Oppgave. Virksomhetens oppgaver har grønn bakgrunn.



Oppgave. Systemeiers oppgaver har blå bakgrunn



Eventuelle hjelpemidler og verktøy kommunen har utviklet for å bistå i oppgaven. Hjelpemidler i <klammer> er planlagt, men eksisterer ikke ennå.



Eventuell tilleggsinformasjon eller anbefalinger.

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

1.1 Veilederens målgruppe og oppbygging

Målgruppen for veilederen er alle ledere og ansatte i Oslo kommune som har et ansvar for eller en rolle i risikostyring av informasjonssikkerhet i egen virksomhet, for en tjeneste/system, eller i en sektor.

Veilederen er inndelt i fem hovedkapitler med ulike hovedmålgrupper:

- **Kapittel 2** gir en generell introduksjon til risikostyring, og er nyttig for **alle** som ønsker kunnskap om risikostyring uavhengig av fagområde.
- **Kapittel 3** omhandler risikostyring av informasjonssikkerhet på de ulike nivåene (byrådsavdeling, virksomhet og systemeier) i Oslo kommune og hvilke oppgaver disse har innen risikostyring. **Kapittel 4** beskriver rammer og prinsipper for risikostyring av informasjonssikkerhet og hvilke oppgaver som bør gjøres. Kapitlene er spesielt rettet mot roller som har et ansvar for risikostyring, som **kommunaldirektører, virksomhetsledere, og øvrige ledere**.
- **Kapittel 5** omhandler metodikken for risikostyring, og med beskrivelse av hver av metodikkens aktiviteter. Kapitlet er spesielt rettet mot **informasjonssikkerhetskordinatorer, systemeiere, og øvrige** som jobber med risikostyring og risikovurderinger av informasjonssikkerhet.

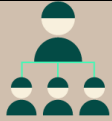
Hovedfokuset i veilederen ligger på risikostyringsprosessen på et overordnet nivå. På felles intranett finnes det eget veilednings- og opplæringsmateriale for gjennomføring av en risikovurdering og bruk av risikovurderingsverktøy.

1.2 Roller og ansvar

Det er virksomhetsleder som er ansvarlig for risikostyringen av informasjonssikkerhet i egen virksomhet. For å få til at risikostyringen fungerer i praksis og er effektiv, må organiseringen i virksomheten støtte opp om dette ansvaret gjennom tydelig og dokumentert delegering, mandat og prosesser. Hvordan ansvaret plasseres og delegeres i virksomheten beskrives i styringssystemet. I tabellen nedenfor er ansvar for ulike roller i kommunen beskrevet.

Rolle	Ansvar
Kommunaldirektør 	Har ansvar for risikostyring innen egen sektor. Dette innebærer å • beslutte akseptabel risiko på sektornivå basert på innspill fra den enkelte virksomhet i egen sektor. • følge opp at sektorens virksomheter opererer innenfor akseptabelt risikonivå • sørge for at det gjennomføres risikovurderinger for sektorsystemer og følge opp at tiltak er gjennomført
Virksomhetsleder	Har ansvar for risikostyring i egen virksomhet. Dette innebærer å • definere og vedlikeholde akseptabelt risikonivå innenfor rammene gitt av overordnet byrådsavdeling. • kartlegge og verdivurdere all informasjon som virksomheten behandler.

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

	• jevnlig gjennomføre risikovurderinger av informasjons-behandlingsprosesser og av egne systemer i virksomheten. • iverksette nødvendige tiltak og/eller fremlegge restrisiko ut over akseptabelt risikonivå for overordnet byrådsavdeling.
Systemeier 	En systemeier har ansvar for risikostyring i det systemet de har ansvar for. Vanligvis inkluderer dette å sørge for at systemet tilfredsstiller relevante krav med hensyn på informasjonssikkerhetsrisiko. Dette innebærer å • kartlegge og verdivurdere informasjon som systemet behandler. • sikre at informasjonssikkerhet ivaretas i avtaler med leverandører av applikasjoner, forvaltning og drift. • gjennomføre risikovurderinger ved anskaffelse, videreutvikling og gjennom systemets levetid. • ta stilling til om systemets risiko er akseptabel. • beslutte og følge opp risikoreducerende tiltak som er nødvendige for å oppnå akseptabel risiko. • jevnlig rapportere restrisiko til virksomhetsleder.
Informasjonssikkerhetskoordinator 	Informasjonssikkerhetskoordinatoren skal bistå virksomhetsleder med risikostyring av informasjonssikkerhet i virksomheten. Dette innebærer å • bistå ved gjennomføring av overordnet risikovurdering for informasjonssikkerhet. • koordinere gjennomføringen av risikovurderinger og oppfølging av status. • bistå i å fasilitere virksomhetens risikovurderinger etter behov. • oppfølging av uakseptabel risiko. • rapportere risiko som en del av ledelsens gjennomgang.

2 Risikostyring

2.1 Om risiko og risikostyring

	Risiko er kombinasjonen av konsekvensen som følger av en uønsket hendelse og sannsynligheten for at hendelsen oppstår.
	Risikostyring innebærer å identifisere, vurdere, håndtere og følge opp risiko som kan påvirke tjenesteleveransene i virksomheten negativt.

Figur 1: Risiko og risikostyring

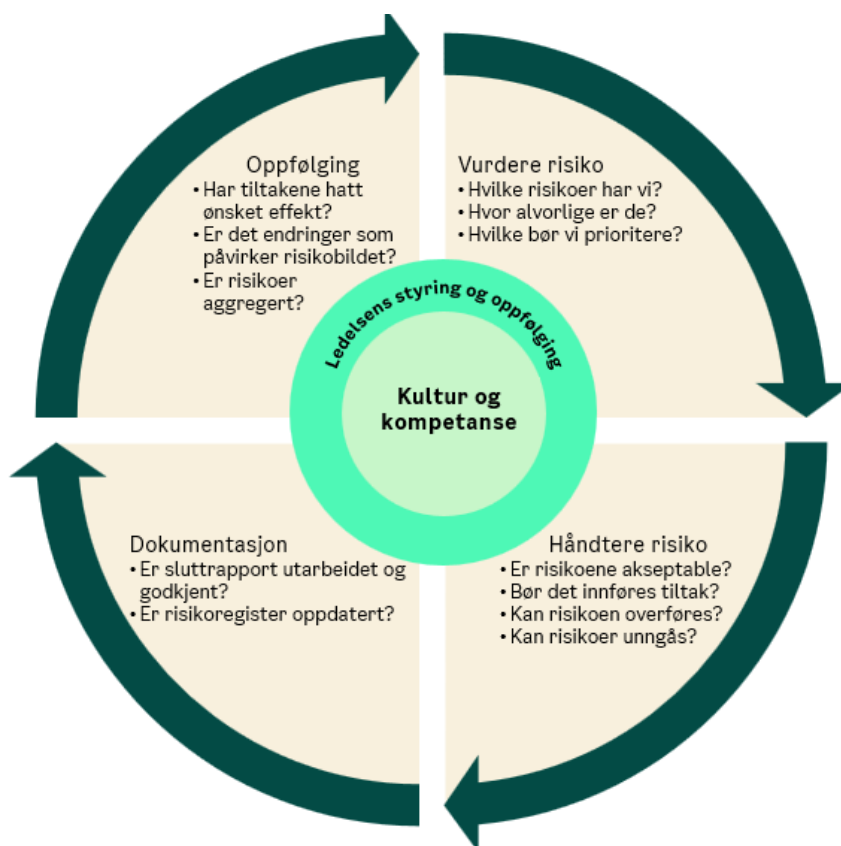
Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

2.2 Formålet med risikostyring

Formålet med risikostyring er å:

- **Beskytte verdier:** Sikre at virksomhetens tjenester, prosesser og informasjon har forsvarlig beskyttelse mot uønskede hendelser.
- **Støtte strategiske mål:** Innarbeide risikostyring i strategiske beslutninger for å sikre at virksomheten kan oppnå sine langsiktige mål.
- **Forbedre beslutningsprosesser:** Gi ledelsen bedre innsikt i risikoer, slik at de kan ta informerte beslutninger.
- **Prioritering:** Bidra til bedre prioritering og ressursstyring.
- **Overholde lover, forskrifter og krav:** Sikre at virksomheten overholder lover, forskrifter og krav
- **Opprettholde tillit og omdømme hos innbyggere og ansatte** ved å ha et forsvarlig sikkerhetsnivå.

Risikostyringsprosessen i figur 2 viser de fire stegene i en risikostyringsprosess; vurdere risiko, håndtere risiko, rapportere risiko og følge opp risiko. Kjernen i dette arbeidet er kompetanse og kultur hos ledere og medarbeidere, og ledelsens styring og oppfølging av risiko.



Figur 2: Risikostyringsprosessen

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

3 Risikostyring av informasjonssikkerhet i Oslo kommune

Informasjonssikkerhet styres av både lovkrav og kommunens egne regler. I henhold til kommunens retningslinjer for styringsdialog og instruks for virksomhetsstyring, skal risikostyring og internkontroll være en del av virksomhetsstyringen. Risikostyring som en del av virksomhetsstyringen bidrar til å beskytte virksomheten mot mulige og relevante trusler, sikre kontinuerlig drift og oppnå virksomhetens mål på en effektiv måte.

Tiltak og prioriteringer skal være basert på risiko slik at et forsvarlig og akseptabelt risikonivå oppnås. Både byrådsavdelingene og virksomhetene har krav, ansvar og oppgaver innen styring og oppfølging for å sikre at dette oppnås. Risikostyring innebærer ofte en avveining mellom kostnadene ved å iverksette tiltak og nytten av å redusere risikoen. Dette kan være en utfordrende balanse å oppnå. Ved å sammenstille risikoer på ulike fagområder vil et helhetlig bilde av virksomhetens risikoer oppnås.

Nedenfor er det overordnet beskrevet hvilke oppgaver byrådsavdelingen, virksomheten, og systemeier har ansvar for. Disse oppgavene er delt inn i etableringsoppgaver, det vil si oppgaver som danner grunnlaget for risikostyringen, og gjentakende oppgaver som gjøres jevnlig og når det oppstår behov.

3.1 Byrådsavdelingens styring og oppfølging

Byrådsavdelingene har en viktig rolle i styring og oppfølging av virksomheter i egen sektor. Informasjonssikkerhet skal inngå i den øvrige virksomhetsstyringen byrådsavdelingen utøver, som inkluderer flere oppgaver beskrevet i tabellen nedenfor. Disse oppgavene er ytterligere beskrevet i «Byrådsavdelingens informasjonssikkerhetsoppgaver».

 Etableringsoppgaver	Oppgaver fra «Byrådsavdelingens informasjonssikkerhetsoppgaver» • Beslutt nivå for akseptabel risiko i hver enkelt virksomhet, basert på forslag fra virksomhetene • Beslutte akseptabelt risikonivå for sektoren • Kartlegge hvilke informasjonssikkerhetskrav og -bestemmelser som gjelder for sektoren
 Gjentagende oppgaver	Oppgaver fra «Byrådsavdelingens informasjonssikkerhetsoppgaver» • Følge opp risikobildet hos virksomhetene • Gjennomføre overordnet risikovurdering for sektoren • Følge opp uakseptabel risiko

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

3.2 Virksomhetsledelsens styring og oppfølging

Ledelsens styring og oppfølging er en sentral del av virksomhetens internkontroll. Her legger virksomhetsledelsen føringer for informasjonssikkerhetsarbeidet som en del av den øvrige virksomhetsstyringen, slik at virksomhetens mål oppnås og tjenestene leveres.

Ledelsen har derfor flere oppgaver innenfor risikostyringen av informasjonssikkerhet. Gjentakende oppgaver følges opp i styringsdialogen, og det kan være smart å legge dem inn i virksomhetens årshjul. Oppgavene bør også være et fast punkt på virksomhetens årlige «Ledelsens gjennomgang» ved å vurdere hvor godt arbeidet med risikostyring fungerer. Endringer i organisasjonen, tjenester, teknologi eller trusselbildet er først og fremst førende for hvor ofte gjentakende oppgaver skal utføres, men endringer kan også bety at en etableringsoppgave må gjentas. For eksempel kan det være geopolitiske endringer gjør at virksomhetsledelsen får en lavere risikoappetitt.

Virksomhetene har flere oppgaver som er beskrevet i tabellen nedenfor. Disse oppgavene er ytterligere beskrevet i «Virksomhetens informasjonssikkerhetsoppgaver».

 Etableringsoppgaver	Oppgaver fra «Virksomhetens informasjonssikkerhetsoppgaver» - Definer nivå for akseptabel risiko i virksomheten, og få det besluttet av egen byrådsavdeling - Sørg for at informasjonssikkerhet inngår i virksomhetsstyringen - Beskriv styrings- og kontrollmiljø for informasjonssikkerhet i virksomheten - Roller og ansvar, inkl. fullmakter og rapporteringslinjer Tilleggsoppgaver - Utarbeid risikokriteriene for virksomheten og få det besluttet av egen byrådsavdeling - Etabler en policy for risikostyring av informasjonssikkerhet - Deleger myndighet og oppgaver til roller og funksjoner i virksomheten
 Gjentagende oppgaver	Oppgaver fra «Virksomhetens informasjonssikkerhetsoppgaver» - Sørg for å ha oversikt over informasjonsverdier - Hold oversikt over hvilke krav virksomheten er underlagt - Gjennomfør risikovurderinger, både på overordnet nivå og for de enkelte prosesser og systemer - Håndter uakseptabel risiko med risikoreduserende tiltak Tilleggsoppgaver - Kartlegg behov for ressurser og kompetanse på informasjonssikkerhet - Vedlikehold et risikoregister for alle virksomhetens risikoer, og følg opp arbeidet i styringsdialogen med egen byrådsavdeling

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

3.3 Systemeiers styring og oppfølging

Systemeier har ansvar for at informasjonssikkerheten ivaretas i systemet de er eier for gjennom hele systemets levetid. Risikostyring inngår som en del av dette ansvaret hvor sentrale oppgaver inkluderer at det informasjonsverdier i systemet kartlegges, at det gjennomføres risikovurderinger, og at risikoer håndteres slik at systemet er innenfor akseptabel risiko.

Systemet har flere oppgaver innen risikostyring i henhold til tabellen nedenfor. Øvrige oppgaver for systemeier er beskrevet i «Systemeiers informasjonssikkerhetsoppgaver».

 Gjentagende oppgaver	Oppgaver fra «Systemeiers informasjonssikkerhetsoppgaver» • Sørg for å ha oversikt over informasjonsverdier som behandles i systemet • Hold oversikt over hvilke krav som gjelder for systemet • Gjennomfør risikovurdering av systemet • Håndter uakseptabel risiko med risikoreduserende tiltak
--	--

4 Rammer for risikostyring av informasjonssikkerhet

4.1 Kultur og kompetanse

Risikostyring av informasjonssikkerhet krever god sikkerhetskompentanse og en god sikkerhetskultur i hele virksomheten. Kultur og kompetanse er altså kjerneelementer i arbeidet med risikostyring av informasjonssikkerhet (se figur 2 i kapittel 2 ovenfor).

Risikostyring handler om mer enn å gjennomføre risikovurderinger og innføre sikkerhetstiltak. Det er en kontinuerlig prosess som involverer alle medarbeidere. Alle må ha tilstrekkelig kompetanse til å oppdage og rapportere risikoer, som uønskede hendelser eller avvik. De må også kunne vurdere om sikkerhetstiltak, som retningslinjer eller adgangskontroll, fungerer som tiltenkt. For eksempel kan ansatte trenes i å identifisere phishing-angrep eller svakheter i fysiske sikkerhetstiltak.

Selv om noen roller må ha særskilt kompetanse, som en fasilitator av risikovurdering og ledere, må alle medarbeidere ha en grunnleggende forståelse av informasjonssikkerhet og risiko. En god sikkerhetskultur innebærer at medarbeidere tar ansvar for sikkerheten i sitt daglige arbeid. Dette kan oppnås gjennom regelmessig opplæring, simuleringer av sikkerhetshendelser og klare rutiner for avviksrapportering.

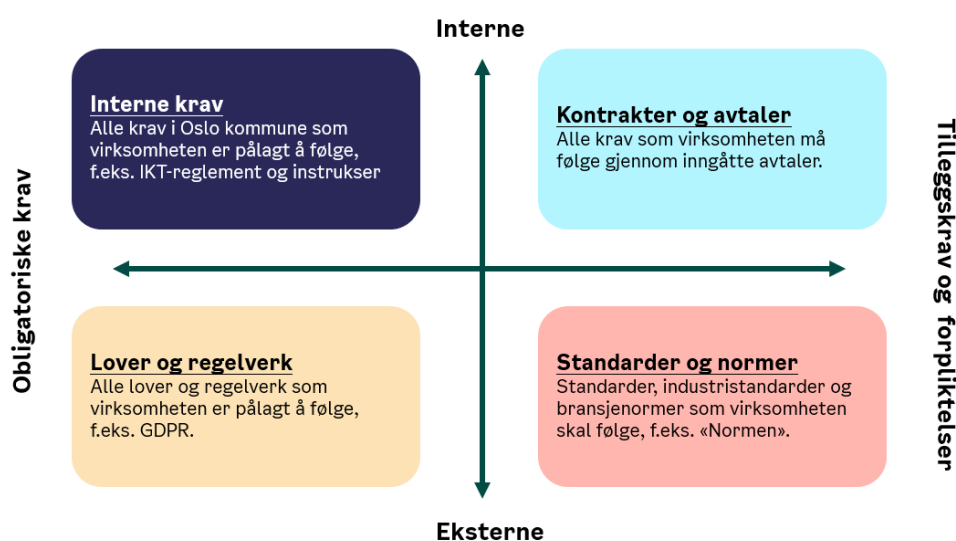
Ledelsens rolle er en forutsetning for å lykkes i arbeidet med risikostyring av informasjonssikkerhet. Ledere må derfor vise engasjement gjennom handlinger, som å prioritere sikkerhet i møter og støtte informasjonssikkerhetskoordinatorer med ressurser. For eksempel kan ledelsen sørge for at informasjonssikkerhet er et fast punkt på agendaen i avdelingsmøter.

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

4.2 Krav til informasjonssikkerhet og risikostyring

Byrådsavdelingene, virksomhetene og systemeierne er underlagt krav til informasjonssikkerhet. Dette krever at det gjennomføres risikovurderinger, og at risikoer håndteres for å oppnå et akseptabelt risikonivå. Krav til risikostyring er kartlagt i kravoversikten i «Rammeverk for informasjonssikkerhet». Systemeiere, virksomhetene og byrådsavdelingene må selv kartlegge hvilke andre tilleggskrav de kan være underlagt. Eksempelvis stiller digitalsikkerhetsloven, personopplysningsloven, og Norm for informasjonssikkerhet og personvern i helse- og omsorgssektoren krav til informasjonssikkerhet og risikostyring.

Figur 4 viser hvor krav og føringer til informasjonssikkerhet og risikostyring kan komme fra.



Figur 4: Kilder til krav og føringer

Det finnes flere krav til når en risikovurdering skal gjennomføres, og som virksomheten må etterleve. Slike vurderinger må som minimum gjennomføres i følgende situasjoner:

- **Før behandling av personopplysninger:** For å identifisere og håndtere risikoer ved behandling av personopplysninger. Dette er spesielt viktig for å overholde GDPR.
- **Før anskaffelse, utvikling og innføring av nye tjenester og systemer:** For å identifisere og håndtere risikoer før nye tjenester, systemer eller teknologier tas i bruk.
- **Ved endringer i eksisterende tjenester eller systemer:** Som en del av internkontroll bør risikovurderinger gjennomføres jevnlig for å identifisere og håndtere nye risikoer, f.eks. endringer i trusselbildet, funksjonalitet, eller teknologi.
- **Overordnet risikovurdering:** Ledelsen bør sørge for at det gjennomføres risikovurderinger på et overordnet nivå som en del av deres ansvar for styring og kontroll av informasjonssikkerheten.

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

4.3 Policy for risikostyring

Virksomhetene har krav til å ha et styringssystem for informasjonssikkerhet. Som en del av styringssystemet for informasjonssikkerhet bør virksomhetene utarbeide en policy for risikostyring av informasjonssikkerhet (en policy er også ofte omtalt som standard i et styringssystem for informasjonssikkerhet). Dokumentet bør være i henhold til risikostyringen på andre fagområder, og i henhold til de lovverk, forskrifter, regler og krav som virksomhetene er forpliktet til å følge. Øvrige tilleggskrav som er besluttet av byrådsavdeling og av virksomhetene selv må også inngå i dokumentet. Følgende områder bør inkluderes i policy for risikostyring

- Roller, ansvar og myndighet
- Krav til risikostyring
- Risikoakseptkriterier og nivå for akseptabel risiko
- Konsekvens- og sannsynlighetskriterier
- Når skal det gjøres risikovurderinger
- Metodikk for risikostyring

Hver av disse områdene er beskrevet i dette veiledningsdokumentet.

	Etabler en policy for risikostyring av informasjonssikkerhet
	<Policy for risikostyring av informasjonssikkerhet>
	Policyen/bestemmelsen for risikostyring av informasjonssikkerhet må være dokumentert og bestå av en anerkjent metode for risikostyring. Dokumentet bør forankres og godkjennes hos virksomhetens øverste leder.

4.4 Delegering av myndighet og oppgaver

Virksomhetsledelsen bør delegere myndighet til ulike roller i virksomheten for å få til en effektiv og god gjennomføring av oppgavene innen risikostyring, f.eks. hvem som har ansvar for gjennomføring av risikovurderinger og kan ta beslutninger. Det er viktig å huske på at dette ikke fratar virksomhetsledelsen hovedansvaret, slik at delegeringen må følges opp av ledelsen på en systematisk og hensiktsmessig måte.

Oppgaver kan delegeres til roller og funksjoner i virksomheten vil bidra til å kunne effektivisere gjennomføring av de gjentakende oppgavene over tid. De roller og funksjoner som får oppgavene, må være i stand til å gjennomføre dem, somr at de har riktig kompetanse.

	Delegerer myndighet og oppgaver til roller og funksjoner i virksomheten
---	--

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

	<u>Rollekort</u>
	Delegering av myndighet og oppgaver til andre roller og funksjoner i virksomheten vil ofte bidra til en mer effektiv styring og håndtering av risikoer. Det er virksomhetsledelsen som bestemmer hva, hvordan og til hvilke roller og funksjoner myndighet og oppgaver delegeres til. For eksempel er det vanlig at virksomhetsledelsen delegerer oppgaver til virksomhetens informasjonssikkerhetskoordinator. Et annet eksempel er at virksomhetsledelsen delegerer myndighet til systemeiere med ansvar for gjennomføring av risikovurdering av systemet de er eier for. Dette er vanligvis det vi omtaler som delegering av risikoeierskap.

4.5 Risikokriterier

For å ha god risikostyring må det finnes kriterier å følge. Risikokriterier hjelper virksomheten med å avgjøre hvilke risikoer som er akseptable og når det er nødvendig å gjøre noe for å redusere risikoen. Virksomheten må utarbeide risikokriteriene, som så må godkjennes av sektorens byrådsavdeling. Ansvar og myndighet for disse områdene er beskrevet i dette kapitlet.

	Utarbeid risikokriteriene for virksomheten og få det besluttet av egen byrådsavdeling
	Eksempel på akseptabelt risikonivå, samt konsekvens- og sannsynlighetskriterier ligger som en del av « <u>Verktøy for risikovurdering (XLS)</u> ».
	Virksomheten må definere et akseptabelt risikonivå og risikoakseptkriterier. Dette inkluderer konsekvenskategorier- og nivåer, samt sannsynlighetskategorier- og nivåer. Disse kriteriene må samsvare med sektorens byrådsavdeling. F.eks. må terskelverdiene mellom ulike konsekvensnivåer defineres på økonomiske konsekvenser. Oppgaven fra virksomhetens informasjonssikkerhetsoppgaver «Definer nivå for akseptabel risiko i virksomheten, og få det besluttet av egen byrådsavdeling» er en del av denne oppgaven.

4.5.1 Risikoakseptkriterier

Vi skiller mellom det vi anser som akseptabel risiko (grønn farge) og uakseptabel (rød farge) risiko, men det er ofte lite praktisk å sette et så skarpt skille mellom hva som er uakseptabelt og akseptabelt.

I Oslo kommune benytter vi fargekodene grønn/gul/rød (se risikomatrisen i figur 5), hvor gul farge utgjør området mellom det vi anser som uakseptabel risiko og akseptabel risiko.

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

Risikonivået, altså hvilken farge risikoen får, bestemmes ut fra konsekvensen og sannsynligheten ved en uønsket hendelse. Jo høyere konsekvens og sannsynlighet, jo høyere vil risikoen bli.

Sannsynlighet	5- Svært stor					
	4- Stor					
	3- Moderat					
	2 - Liten					
	1 - Meget liten					
		1 - Ubetydelig	2- Lav	3- Moderat	4 - Alvorlig	5 - Svært alvorlig
		Konsekvens				

Figur 5 – Risikomatrise og nivå for akseptabel risiko

Risikonivåene legger grunnlaget for risikoakseptkriteriene, og beskriver betingelsene for hvordan risikonivåene (grønn/gul/rød) skal håndteres i virksomheten. Betingelsene kan for eksempel være hvilket ledernivå/rolle som kan akseptere hvilket risikonivå, og om risikoen skal rapporteres til egen byrådsavdeling.

Eksempel på risikonivå, beskrivelse og kriterier for å akseptere risiko er beskrevet i «Tabell 1: Risikoakseptkriterier».

Risikonivå	Beskrivelse	Kriterier for å akseptere risiko
Lav	Tiltak er ikke nødvendig	Akseptabelt risikonivå. Risiko kan aksepteres av ledere på alle nivåer uten å vurdere eller iverksette nye tiltak.
Middels	Risikoreduserende tiltak skal vurderes.	Risiko må følges opp. Risikoen kan kun aksepteres av tjenesteeier/systemeier eller virksomhetsleder.
Høy	Risikoreduserende tiltak skal normalt iverksettes.	Risikonivået er uakseptabelt. Risikoen kan kun aksepteres av virksomhetsleder og skal rapporteres til overordnet byrådsavdeling.

Tabell 1: Risikoakseptkriterier

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

4.5.2 Konsekvenskategorier- og nivåer

Konsekvenskategorier og antall konsekvensnivåer bør samsvare med de andre virksomhetene i sektoren slik at det er mulig å sammenstille et risikobilde på sektornivå.

Konsekvenskategorier

Konsekvenskategorier er ulike områder som kan bli negativt påvirket av en risiko. De hjelper virksomheten med å forstå hvilke typer skader eller tap som kan oppstå.

Som et minimum, anbefales det å vurdere bruk av følgende konsekvenskategorier, se Figur 6:

				
Liv og helse	Økonomi	Tillit / Omdømme	Lover, forskrifter og krav	Måloppnåelse

Figur 6: Eksempel på Konsekvenskategorier

Andre konsekvenskategorier kan legges til, f.eks. personvern. Dette gjøres i samarbeid med sektorens byrådsavdeling.

Konsekvensnivåer

Konsekvensnivåer beskriver hvor alvorlig en hendelse kan være innenfor hver konsekvenskategori. De hjelper virksomheten med å vurdere hvor stor skaden eller tapet kan bli. Det er anbefalt å benytte en skala med fem konsekvensnivåer (se Figur 7).

I hvilken grad konsekvenskategoriene påvirkes				
Ubetydelig	Lav	Moderat	Alvorlig	Svært alvorlig

Figur 7 Eksempel på Konsekvensnivåer, med konsekvenser fra Ubetydelig til Svært alvorlig

Hvordan beskrive konsekvenskategorier og konsekvensnivåer

- Identifisere kategorier:** Identifiser hvilke områder som er viktige for virksomheten (f.eks. måloppnåelse, økonomi).
- Definere nivåer:** Beskriv hvor alvorlig en hendelse kan være for hver kategori (f.eks. ubetydelig, lav, moderat, alvorlig, svært alvorlig), og utarbeid forslag til terskelverdier for nivåene.
- Samarbeid:** Arbeid sammen med relevante avdelinger for å sikre at kategoriene og nivåene er relevante og forståelige.
- Dokumentere:** Lag en oversikt over kategoriene og nivåene, og sørg for at alle i virksomheten kjenner til dem.

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

4.5.3 Sannsynlighetskategorier- og nivåer

Sannsynlighetskriterier hjelper virksomheten med å vurdere hvor sannsynlig det er at en uønsket hendelse vil skje. De beskriver hvor **ofte** og/eller hvor **lett** hendelsen kan inntreffe.

Sannsynlighetskriterier beskrives gjennom sannsynlighetskategorier og sannsynlighetsnivåer.

Sannsynlighetskategorier

Sannsynlighetskategoriene kan bestemmes av flere faktorer, og kan inkludere om hendelser er tilsiktede, utilsiktede, eller farer.

Hvor ofte skjer det? Hovedregel: Brukes dersom det finnes historikk		Hvor lett skjer det? Hovedregel: Brukes dersom det finnes begrenset med eller ingen historikk		
Forventning	Estimert sannsynlighet på frekvens	Sårbarhet	Kapasitet og evne	Intensjon
Hvor ofte forventes den uønskede hendelsen å inntreffe?	Hva er sannsynligheten på frekvensen av den uønskede hendelsen?	Har vi tilstrekkelige tiltak for å håndtere sårbarhetene?	Hvilken kapasitet og evne har trusselkilden/aktøren?	Hva er intensjonen bak handlingen, er det tilsiktet eller utilsiktet?

Figur 8: Eksempel på Sannsynlighetskategorier

Sannsynlighetsnivåer

Det er anbefalt å benytte en skala med fem sannsynlighetsnivåer (se Figur 9). Nivåene beskriver grensene for hvor ofte og hvor lett en uønsket hendelse kan forventes å inntreffe.

I hvilken grad sannsynlighetskategoriene påvirkes				
Meget liten	Liten	Moderat	Stor	Svært stor

Figur 9: Eksempel på Sannsynlighetsnivåer, med sannsynlighet fra Meget liten til Svært stor

4.6 Risikoregister

Virksomhetene bør etablere et risikoregister for å holde oversikt på alle informasjonssikkerhetsrisikoer. Dersom mulig bør også risikoregisteret med informasjonssikkerhetsrisikoer være en del av virksomhetens helhetlige risikoregister på andre fagområder slik at byrådsavdelingene og virksomhetene har et godt bilde av risikoene på eget område.

Som minimum bør følgende elementer inngå i risikoregisteret:

- Risikoscenario
- Risikonivå og eventuell restrisiko
- Risikoeier
- Tiltak, og status på tiltakene
- Tiltakseier(e)

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

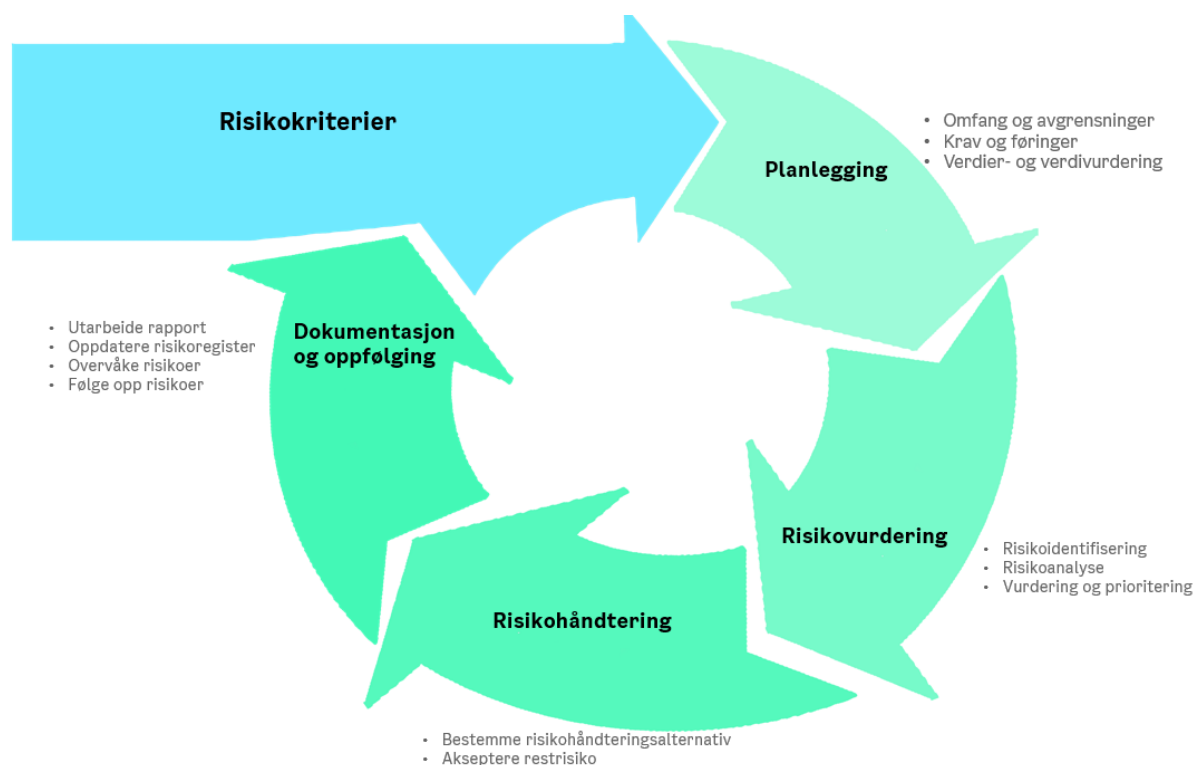
- Dato for siste revidering

Fagområde og type risiko (operativ, strategisk, etterlevelse osv.) bør vurderes, spesielt dersom risikoregisteret også skal omfatte andre fagområder enn informasjonssikkerhet

	Vedlikehold et risikoregister for alle virksomhetens risikoer, og følg opp arbeidet i styringsdialogen med egen byrådsavdeling
	Eksempel på risikoregister fra BLK
	For en helhetlig oversikt over virksomhetens risikoer, bør virksomhetsledelsen etablere og vedlikeholde et risikoregister på virksomhetsnivå. Her bør alle virksomhetens risikoer, uavhengig av fagområde, registreres.

5 Metodikk for risikostyring av informasjonssikkerhet

For at virksomhetene i kommunen skal være i stand til å ha forsvarlig styring og kontroll med informasjonssikkerheten, er det viktig å etablere en metodikk med systematiske aktiviteter innen risikostyring. En slik metodikk vil sikre helhetlig tilnærming for å identifisere, håndtere, dokumentere og følge opp informasjonssikkerhetsrisikoer i virksomheten og til egen byrådsavdeling. Prosessen for risikostyring i Oslo kommune innebærer følgende aktiviteter:



Figur 10: Risikostyringsprosessen

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

Det er utarbeidet eget veiledningsmateriale for risikovurdering «**Veileder i risikovurdering av informasjonssikkerhet**», som beskriver aktivitetene i risikovurderingen mer detaljert.

5.1 Planlegging

5.1.1 Omfang og avgrensninger

Det er viktig å bestemme hva som skal omfattes av risikovurderingen og dokumentere dette. Dette sikrer at alle har samme forståelse av omfang og at vurderingen ikke blir for omfattende. Det må være klart hvilke aktiviteter, prosesser og informasjonsverdier som vurderes, og hva som ikke er omfattet.

5.1.2 Krav og føringer

Informasjonssikkerhet er regulert gjennom flere lover og forskrifter, i tillegg til flere andre krav og føringer, blant annet gjennom reglement og instruks Oslo kommune. Det er viktig å identifisere hvilke krav som gjelder innen omfanget av risikovurderingen, og sikre at disse følges. Dette kan for eksempel inkludere spesifikke sikkerhetstiltak som kryptering og tilgangsstyring.

5.1.3 Verdier og verdivurdering

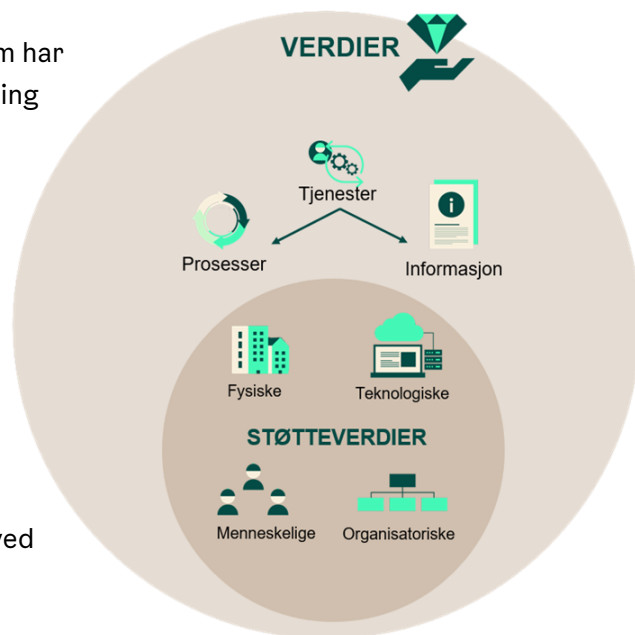
Før risikovurderingen må virksomheten kartlegge sine verdier. Verdiene deles inn i:

- **Verdier:** Aktiviteter, prosesser og informasjon som har verdi for virksomheten og brukerne (f.eks. behandling av en søknad, personopplysninger og helseopplysninger).
- **Støtteverdier:** Verdier som støtter verdiene (f.eks. IKT-utstyr, elektronisk pasientjournal).

Å forstå sammenhengen mellom verdier og støtteverdier er viktig, da sårbarheter, svakheter og andre problemer i eller med støtteverdiene kan medføre negative konsekvenser for verdiene. En verdivurdering ser med andre ord på de negative konsekvenser for verdiene ved brudd på konfidensialitet, integritet og tilgjengelighet.

I Oslo kommune bruker vi konsekvensnivåene og konsekvenskategoriene for å vurdere alvorlighetsgraden ved uønskede hendelser, som går fra *ubetydelig* til *svært alvorlig*.

Mer om verdier og verdivurdering finnes i temaveileder for verdier.



Figur 11: Verdier og støtteverdier

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

5.2 Risikovurdering

En risikovurdering hjelper virksomheten med å forutse og forebygge uønskede hendelser, og evaluere risikoene mot nivået for akseptabel risiko. Risikovurdering består av tre deler: risikoidentifisering, risikoanalyse og risikoprioritering.

5.2.1 Risikoidentifisering

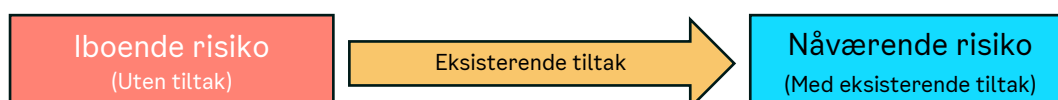
Risikoidentifisering handler om å finne realistiske uønskede hendelser innenfor det bestemte omfanget. Dette gjøres for å finne ut hva som kan gå galt. Det er viktig å bruke tid og ressurser på dette.

Det er vanligvis to tilnærminger til risikoidentifisering som benyttes:

- **Overordnet («top-down»):** Fokus på hendelser som kan oppstå, kilden til hendelsen (f.eks. hackere eller strømbrydd), og hvordan disse påvirker virksomhetens tjenester, prosesser og informasjonsverdier negativt. Denne tilnærmingen egner seg godt å gjennomføre sammen med ledergrupper på ulike nivåer, dersom virksomheten ikke har en god oversikt over sine verdier og støtteverdier og hvilke trusler og sårbarheter disse kan utsettes for, eller om virksomheten har et lavt modenhetsnivå på informasjonssikkerhetsområdet.
- **Verdibasert:** Fokus på hendelser knyttet til hvordan trusler utnytter sårbarheter i støtteverdiene (som f.eks. PCer eller nettverk) som igjen påvirker virksomhetens verdier negativt. Denne tilnærmingen egner seg godt dersom virksomheten har god oversikt på verdier, støtteverdier, trusler og sårbarheter, eller som det skal gjøres en risikovurdering av noe konkret, f.eks. et system eller en anskaffelse.

5.2.2 Risikoanalyse

Risikoanalyse vurderer hvor høy eller lav en risiko er ved å se på konsekvensen av og sannsynligheten for en uønsket hendelse. Summen av disse vurderingene bestemmer risikonivået. Det kan være ulike oppfatninger om risikonivået, fordi vurderingene ofte er subjektive og basert på erfaringer. Vurdering av sårbarheter og svakheter, samt effekten av eksisterende sikkerhetstiltak kan også variere. Som hovedregel vil nåværende risiko (blå firkant) vurderes, som vil si at vi bestemmer et nåværende risikonivå som inkluderer de sikkerhetstiltakene virksomheten allerede har på plass.



Hvordan gjøre risikoanalyse?

- **Konsekvens:** Vurder hvor alvorlig en hendelse vil være for virksomheten.

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

- **Sannsynlighet:** Vurder hvor sannsynlig det er at en hendelse skjer, basert på frekvens og/eller letthet.

Bestemme risikonivå:

- Kombiner konsekvens og sannsynlighet for å bestemme risikonivået.
- Bruk en risikomatrise som viser risikonivået i rød, gul eller grønn sone.

Sannsynlighet	5 - Svært stor					5
	4 - Stor	2				
	3 - Moderat			1	7	
	2 - Liten		3	6 4		
	1 - Meget liten					
		1 - Ubetydelig	2 - Lav	3 - Moderat	4 - Alvorlig	5 - Svært alvorlig
		Konsekvens				

Figur 12: Eksempel på identifiserte risikoer hvor risikonivå er bestemt og lagt inn i risikomatrisen

5.2.3 Risikoprioritering

Når risikonivået er satt, vurderes risikoene mot hva som er akseptabel risiko. Risikoer utenfor akseptabelt nivå prioriteres for håndtering, med de høyeste risikoene først. I eksempelet ovenfor ligger risiko 5 og 7 i rød sone. Risiko 5 har høyere konsekvens og sannsynlighet, og derfor bør risiko 5 prioriteres over risiko 7. Risikoer i gult område bør også prioriteres for videre behandling, mens risikoer i grønn sone normalt aksepteres uten videre håndtering.

5.3 Risikohåndtering

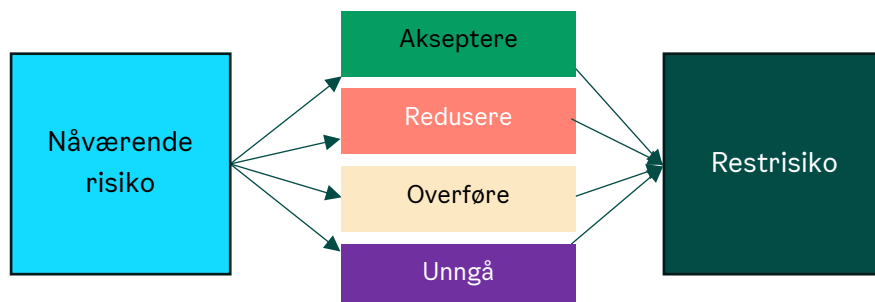
Ledelsen har ansvar for å beslutte om en risiko kan aksepteres. Selv om koordinatorene, fagpersoner og fasilitatorer kan gjennomføre risikovurderinger, er det virksomhetsleder, risikoeier og i noen tilfeller sektorens byrådsavdeling som tar den endelige beslutningen om risikoaksept. Det er derfor viktig at risikovurderingene har god kvalitet, slik at den fungerer som et tilstrekkelig beslutningsgrunnlag.

Risikoaksept bestemmes av de kriteriene dere har laget for hvilket ledernivå som kan ta beslutninger om risiko. Alle virksomhetsmål bør kunne nås uten uønskede konsekvenser, men det vil nesten alltid være en sannsynlighet for at uønskede hendelser kan skje. Da må virksomhetsleder eller risikoeier velge mellom å

- **akseptere** risikoen uten å gjøre ytterligere tiltak,
- **redusere** risikoen ved å iverksette sikkerhetstiltak,
- **overføre** risikoen til andre (som et forsikringsselskap),

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

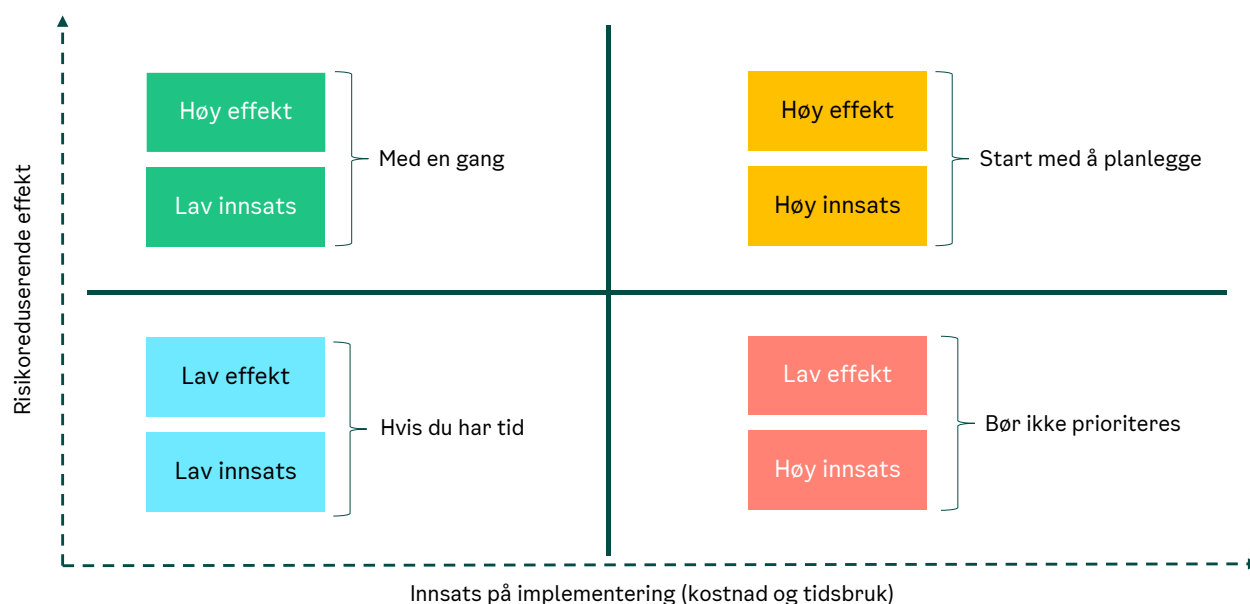
- eller **unngå** aktiviteter, prosesser, informasjon eller behandlinger som medfører risikoen.



Dersom det besluttes å redusere en risiko, kan tiltak enten redusere sannsynligheten for at noe skjer, eller redusere konsekvensene hvis det skjer. Det vil alltid være en viss restrisiko igjen etter en gjennomført risikovurdering og tiltaksplan. Målet er ikke å eliminere risikoen fullstendig, men å redusere den til et akseptabelt nivå.

Tiltakene som iverksettes kan være organisatoriske, teknologiske, fysiske eller menneskelige sikkerhetstiltak. Hvert tiltak må ha en tiltaksansvarlig med tilhørende kostnad og tiltaksfrist. Tiltaksansvarlig kan være en annen enn risikoeier, spesielt hvis tiltaket er i en annen avdeling. Risikoeieren bør derfor foreslå og forankre hvem som er ansvarlig for tiltakene.

Når risikoreduserende tiltak skal innføres, må man vurdere hvilke tiltak som bør prioriteres først. Dette gjøres gjennom en kost-/nyttevurdering, hvor innsats (tid og ressurser) og tiltakets effekt avgjør prioriteringen. Figur 13 nedenfor gir veiledning til prioritering av sikkerhetstiltak.



Figur 13: Forslag til prioritering av sikkerhetstiltak

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

5.4 Dokumentasjon

5.4.1 Risikorapport og kommunikasjon

Det skal utarbeides en risikorapport som dokumenterer resultatene av risikovurderingen. Hensikten er å gjøre resultatene lettere tilgjengelig for lesere som ikke har deltatt i aktivitetene og for ledere og tilsynsmyndigheter ved behov. Risikorapporten må godkjennes av leder på riktig nivå eller tjenesteeier/systemeier, og de må derfor være godt kjent med innholdet i rapporten. Rapporten bør som minimum beskrive følgende:

- oppsummering av prosessen/systemet som er risikovurdert
- kort beskrivelse av metode/fremgangsmåte, samt risikokriterier
- deltakere i risikovurderingen
- omfang og avgrensninger i risikovurderingen
- viktigste risikoer, med eventuelle nye tiltak med ansvarlig og tidsfrist
- akseptert restrisiko etter gjennomføring av besluttede tiltak

Det er utarbeidet en rapportmal som er lagt ut på kommunens felles intranett. I tillegg bør det utarbeides en risikobehandlingsplan. Risikobehandlingsplanen kan være en del av eller et vedlegg til sluttrapporten.

Rapporten inneholder informasjon om sårbarheter, sikkerhetstiltak og eventuelt mangel på tiltak, og må beskyttes mot uautorisert innsyn. Rapporten skal derfor klassifiseres etter hvor sensitivt innholdet er, og tilgang gis etter tjenstlig behov. Underlagsmateriale bør arkiveres som vedlegg rapporten. Risikovurderinger skal som hovedregel arkiveres i Acos Websak+ (arkiveringssystemet).

5.4.2 Oppdatere risikoregister

Som en del av arbeidet med dokumentasjonen av risikovurderingen og risikohåndteringen, så oppdateres risikoregisteret med de nye risikoene som har blitt identifisert i risikovurderingen. Valg av risikohåndteringsalternativ og eventuelt nye tiltak og tilhørende restrisiko legges inn i risikoregisteret.

5.4.3 Effektivisering av risikostyring

Det kan brukes mye tid og ressurser på risikostyring. Samtidig vet vi at mange av verdiene, truslene og sårbarhetene er de samme i hver risikovurdering som gjennomføres. For å gjøre dette arbeidet mer effektivt er det anbefalt at virksomheten, og som en del av styringssystemet for informasjonssikkerhet og personvern, har oversikter på virksomhetsnivå med verdier, trusler, sårbarheter og eksisterende sikkerhetstiltak. Regelmessig oppdatering av disse oversiktene bør gjøres, for eksempel ved innføring av nye tjenester, prosesser og verdier og ved endringer i trusselbildet.

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0

5.5 Oppfølging av risiko

Oppfølging av risikoer er en viktig del av risikostyringsprosessen. Virksomhetene må ha rutiner for rapportering og oppfølging på ulike nivåer, inkludert status og effekten av sikkerhetstiltakene. Kilden til oppfølging og kommunikasjon bør være risikoregisteret.

5.5.1 Overvåke og oppdatere

Virksomhetens prosess for å monitorere risiko vil kunne avdekke om risikostyringen fungerer etter hensikten. For de fleste virksomheter er risikobildet i kontinuerlig endring, og virksomheten bør derfor ha et sett med målinger som kan oppdage endringer som påvirker risikobildet.

- Avvik og informasjonssikkerhetsbrudd kan påvirke risikobildet på informasjonssikkerhet. Slike uønskede hendelser bør derfor følges opp for å avdekke om innførte sikkerhetstiltak ikke er effektive nok, om det identifiseres nye sårbarheter, eller om risikoer kan håndteres på annen måte.
- Ved innføring av nye verdier, eller ved endring av konsekvenser på eksisterende verdier (basert på verdivurdering), bør risikovurderinger gjennomgås for å vurdere om risikonivåene bør endres.
- Endringer i trusselbildet, som for eksempel geopolitiske endringer, som gjør at eksisterende sikkerhetstiltak bør endres eller nye sikkerhetstiltak bør innføres.
- Endringer i krav og føringer som påvirker risikobildet i virksomheten.

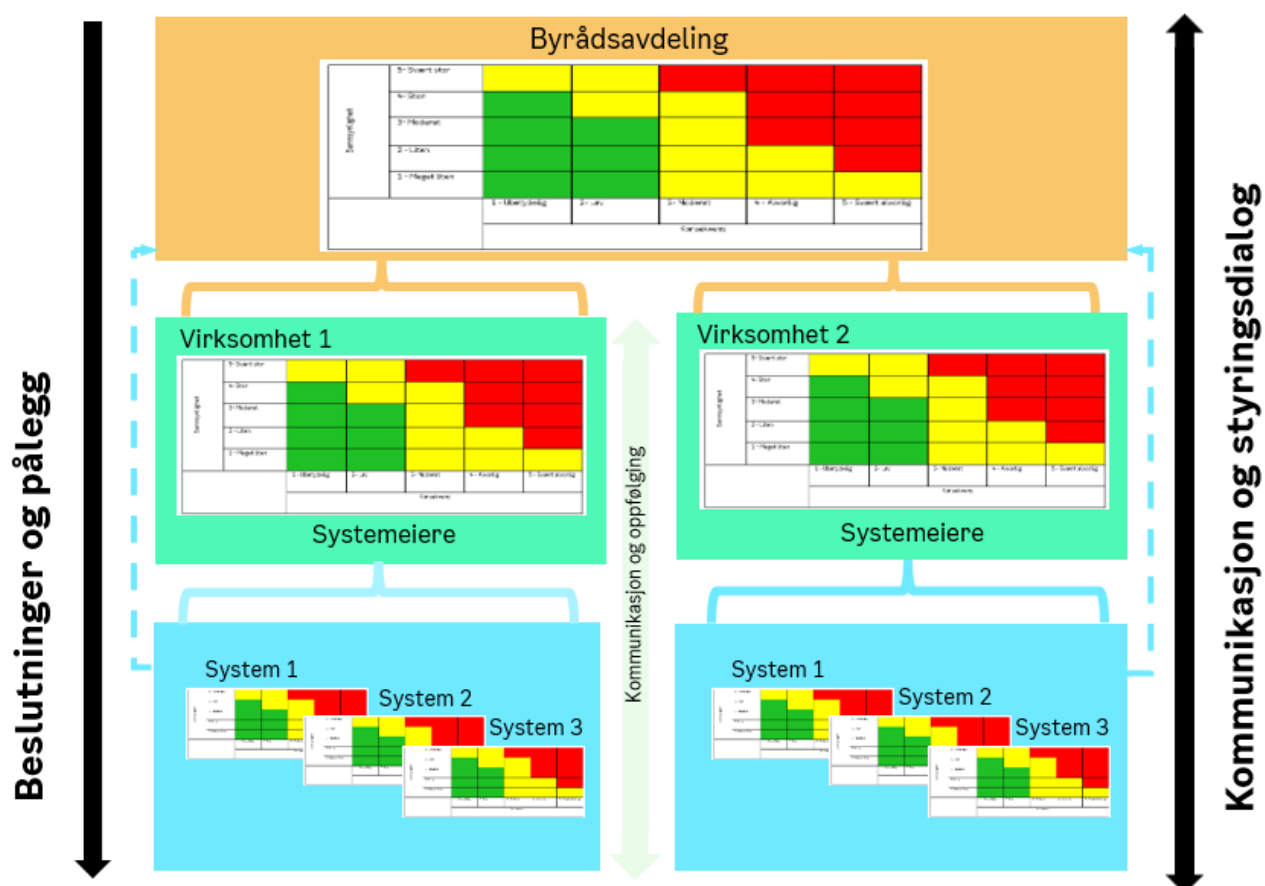
I tillegg bør alle risikovurderinger som gjennomføres ha fastsatt en dato for når risikovurderingen bør gjennomgås på nytt og eventuelt oppdateres. Oppdateringsfrekvens vil variere, men risikovurderingene til særlig kritiske og viktige tjenester og systemer bør gjennomgås årlig, eller når endringer tilsier det.

5.5.2 Følge opp og rapportere risiko

Risikoer og rapportering av status på sikkerhetstiltak bør være en del av den periodiske rapporteringen. For at virksomhetsledelsen skal få en god oversikt over risikoene de står ovenfor, bør risikoer aggregeres slik at ledelsen har en reell mulighet for å vurdere og være informert om de viktigste risikoene, enten risikoene befinner seg i et system, en prosess, eller i en tjeneste. I tillegg er det viktig at risikobildet inngår i ledelsens gjennomgang.

Eksemplet nedenfor viser en forenklet måte å aggregere risikoer på, og hvordan kommunikasjon, og oppfølging kan gjøres. En tilnærming til dette er å aggregere topp 10 risikoer fra hvert enkelt system, og opp til virksomhetsnivå. Videre vil virksomheten aggregere topp 10 risikoer på virksomhetsnivå, som rapporteres til sektorens byrådsavdeling.

Rammeverk for informasjonssikkerhet	Dato	Versjon
Veileder i risikostyring av informasjonssikkerhet	30.09.2025	1.0



Figur 14: Følge opp og rapportere risiko